

Revisión

Seguridad usable: una revisión bibliográfica sistemática

Francesco Di Nocera , Giorgia Tempestini y Matteo OrsiniDepartamento de Planificación, Diseño y Tecnología de la Arquitectura, Universidad Sapienza de Roma,
00196 Roma, Italia; giorgia.tempestini@uniroma1.it (G.T.); matteo.orsini@uniroma1.it (M.O.)

* Correspondencia: francesco.dinocera@uniroma1.it

Resumen: La seguridad usable consiste en diseñar medidas de seguridad que se adapten a las necesidades y comportamientos de los usuarios. Lograr un equilibrio entre la usabilidad y la seguridad plantea retos: cuanto más seguros son los sistemas, menos usables resultan. Por el contrario, los sistemas más usables serán menos seguros. Numerosos estudios han abordado este equilibrio. Estos estudios, que abarcan la psicología y la informática/ingeniería, aportan perspectivas diversas, lo que hace necesaria una revisión sistemática para comprender las estrategias y los hallazgos en este ámbito. Esta revisión bibliográfica sistemática examinó artículos sobre seguridad usable publicados entre 2005 y 2022. Tras su evaluación, se seleccionaron un total de 55 estudios de investigación. Los estudios se han clasificado, a grandes rasgos, en cuatro grupos principales, cada uno de los cuales aborda diferentes aspectos: (1) usabilidad de los métodos de autenticación, (2) ayuda a los desarrolladores de seguridad para mejorar la usabilidad, (3) estrategias de diseño para influir en el comportamiento de los usuarios en materia de seguridad, y (4) modelos formales para la evaluación de la seguridad usable. A partir de esta revisión, constatamos que el estado actual del campo revela cierta inmadurez, ya que los estudios tienden a centrarse en comparaciones entre sistemas en lugar de establecer directrices de diseño sólidas basadas en un análisis exhaustivo del comportamiento de los usuarios. La existencia de un marco teórico y metodológico común es uno de los principales aspectos que deben mejorarse en esta área de investigación. Además, la ausencia de requisitos de seguridad usable en casi todos los contextos de desarrollo desalienta en gran medida la implementación de buenas prácticas desde las primeras fases del desarrollo.

Palabras clave: seguridad usable; usabilidad; seguridad; ciberseguridad; autenticación; desarrolladores; directrices; comportamiento



Cita: Di Nocera, F.; Tempestini, G.; Orsini, M. «Seguridad usable: una revisión sistemática de la literatura». *Information* **2023**, *14*, 641. <https://doi.org/10.3390/info14120641>

Editores académicos: Moutaz Alazab y Ammar Alazab

Recibido: 29 de septiembre de 2023
Revisado: 15 de noviembre de 2023
Aceptado: 28 de noviembre de 2023
Publicado: 30 de noviembre de 2023



Derechos de autor: © 2023 por los autores. Licenciario: MDPI, Basilea, Suiza. Este artículo es de acceso abierto y se distribuye bajo los términos y condiciones de la licencia Creative Commons Attribution (CC BY) (<https://creativecommons.org/licenses/by/4.0/>).

1. Introducción

La seguridad usable se refiere al diseño y la implementación de medidas de seguridad que tienen en cuenta las necesidades, capacidades y comportamientos de los usuarios. A medida que los sistemas se vuelven más seguros mediante la implementación de mecanismos de autenticación y protocolos de cifrado, se vuelven más complejos y menos intuitivos para los usuarios. Esta complejidad puede dar lugar a una curva de aprendizaje más pronunciada, a un mayor esfuerzo necesario para realizar las tareas y a una posible frustración para los usuarios. Por otro lado, los sistemas que dan prioridad a la usabilidad pueden sacrificar algunas medidas de seguridad, lo que los hace más susceptibles a los ciberataques [1].

Por lo tanto, la seguridad usable tiene como objetivo hacer que las medidas de seguridad sean más eficaces minimizando los errores de los usuarios y aumentando el cumplimiento de los protocolos de seguridad por parte de estos.

Cuando el concepto de «seguridad usable» comenzó a difundirse a mediados de la década de 1990, los autores se centraron inicialmente sobre todo en la seguridad de las contraseñas y los correos electrónicos. La seguridad de las contraseñas es un buen ejemplo que ilustra la disyuntiva entre usabilidad y seguridad, debido a la práctica de guardar las credenciales de inicio de sesión por comodidad [2]. Es evidente que almacenar una cadena alfanumérica única y compleja para cada cuenta supone un esfuerzo considerable para el usuario [3], pero, por otro lado, guardar las contraseñas conlleva riesgos. Si un usuario malintencionado accediera al dispositivo o a la cuenta, tendría acceso inmediato a todas las contraseñas almacenadas, lo que comprometería varias cuentas al mismo tiempo. Para evitar estos riesgos, es esencial encontrar un equilibrio entre la usabilidad y la seguridad.

Desde el punto de vista de la seguridad, estrategias como el uso de contraseñas complejas y únicas o su actualización frecuente favorecen la seguridad. Sin embargo, pueden provocar frustración en el usuario.

y la adopción de prácticas inseguras, como anotar contraseñas en superficies de fácil acceso [4].

Sin embargo, estudios posteriores han ampliado el campo de la seguridad usable al investigar cómo integrar interfaces intuitivas, instrucciones claras, procesos de autenticación simplificados y recursos educativos en sistemas que garanticen la seguridad. El objetivo es ayudar a los usuarios a tomar decisiones de seguridad que garanticen tanto la seguridad como la usabilidad sin que ello suponga una carga cognitiva u operativa significativa para ellos.

En los últimos años, numerosos grupos de investigación y organismos han abordado el equilibrio entre seguridad y usabilidad, especialmente tras el aumento del uso de Internet (incluido el teletrabajo y el comercio electrónico) derivado de la pandemia de COVID-19 y el consiguiente incremento significativo de los ciberataques [5–10]. Las contribuciones en este ámbito son muy variadas. Algunas de ellas se enmarcan en las tradiciones de la psicología experimental y social, mientras que otras (muchas) se inscriben en los marcos de la informática y la ingeniería, por citar solo algunos tipos de estudios. Por lo tanto, comprender qué estrategias se utilizan para estudiar este fenómeno y qué resultados se han obtenido de los estudios empíricos es un objetivo que debe perseguirse para poner orden en las contribuciones de la bibliografía.

2. Justificación

Nuestra revisión no es la primera sobre la seguridad usable. Otros investigadores han intentado revisar este campo de estudio en artículos de revistas académicas. Sin embargo, muchas de estas contribuciones carecen de un enfoque sistemático (p. ej., 5, 7, 8). En consecuencia, no exponen los criterios de inclusión y exclusión, y la selección de artículos se basa en la elección narrativa de los autores.

A pesar de ello, hemos identificado algunas revisiones sistemáticas sobre el tema, aunque se centran principalmente en aspectos más específicos y abarcan períodos relativamente breves [6, 11, 12].

Por ejemplo, el trabajo de Distler et al. (2021) tiene como objetivo examinar los métodos empleados en los estudios sobre seguridad y privacidad, centrándose en las cinco publicaciones de congresos revisadas por pares más pertinentes —una elección válida, aunque la inclusión de ponencias de congresos en revisiones sistemáticas no suele ser habitual—. La revisión abarca estudios realizados entre 2014 y 2018, un intervalo limitado y algo arbitrario, sobre todo si se tiene en cuenta el auge observado en la investigación, especialmente en los últimos años, debido a los avances tecnológicos. A pesar de analizar un número considerable de artículos, solo el 6 % llegó a la revisión final.

Lennartson et al. (2021) llevaron a cabo una revisión bibliográfica que abarcaba tanto artículos de revistas como de congresos (de nuevo, una elección poco convencional) para identificar un conjunto exhaustivo de factores que influyen en la usabilidad en un contexto de seguridad, entre los que se incluyen la simplicidad, la información y el soporte, el tiempo de realización de las tareas, las tasas de error y la gestión de errores. A pesar de haber explorado siete bases de datos diferentes en el intervalo 2015–2020, el número de artículos seleccionados no difiere notablemente del considerado en nuestra revisión (70 frente a 55 estudios).

La revisión bibliográfica sistemática de Nowkedi et al. (2016) abordó la brecha entre la usabilidad y la seguridad en el desarrollo de software, haciendo hincapié en la necesidad de integrar el diseño de la usabilidad y la seguridad para lograr un software de calidad para el usuario final. Sin embargo, esta revisión es más sectorial, ya que incorpora exclusivamente trabajos de ingeniería relacionados con el ámbito del desarrollo de software y no presenta una visión general más amplia de la usabilidad y la seguridad.

Teniendo en cuenta las limitaciones observadas en revisiones anteriores, hemos optado por abordar la seguridad usable mediante una revisión sistemática de la literatura basada en los siguientes supuestos:

- Limitar la búsqueda a artículos de revistas académicas, garantizando un mayor control de calidad.
- Examinar un periodo de tiempo considerable (concretamente, de 2005 a 2022).
- Incluir estudios de diversos ámbitos de investigación, en lugar de limitar el alcance exclusivamente a la ingeniería y la informática.

Nuestro objetivo principal es comprender el estado actual de la técnica e identificar las tendencias de investigación predominantes que han recibido reconocimiento a través de su publicación en revistas académicas.

3. Objetivos de investigación y preguntas de investigación

Las preguntas de investigación (P.I.) sirvieron de guía para llevar a cabo la revisión bibliográfica. Basándonos en estas P.I., buscamos y seleccionamos bibliografía desde 2005. La primera P.I., que es también el objetivo principal de esta revisión, es: «¿Cuál es el estado actual de la bibliografía en relación con la seguridad usable?» (P.I. 1). Varios estudios han abordado el tema de la seguridad usable de forma incorrecta al utilizar el término «usabilidad». Por lo tanto, no existe una forma unívoca de abordar la seguridad usable. Esto lleva a la necesidad de profundizar y sistematizar la bibliografía existente. Por este motivo, esta primera pregunta de investigación es relevante para avanzar en el conocimiento sobre este tema.

A continuación, nos propusimos identificar las macroáreas en las que se aborda el tema de la seguridad usable para responder a la pregunta: «¿Cómo pueden clasificarse las contribuciones que se encuentran en la bibliografía?» (RQ2). La bibliografía comprende artículos que abordan numerosas cuestiones, se dirigen a públicos diferentes y hacen referencia a contextos distintos. Tratar estos artículos como parte de una única macroárea podría no resultar útil a la hora de identificar estrategias para abordar cuestiones relacionadas con la ciberseguridad, ya que no se tendría en cuenta su diversidad esencial. Identificar los aspectos que distinguen los distintos contextos permitiría implementar estrategias de seguridad más adecuadas que combinen usabilidad y seguridad. Una vez más, con el objetivo de sistematizar la bibliografía, esta segunda pregunta surge de la necesidad de distinguir los ámbitos en los que podría aplicarse la seguridad usable.

Por último, la última pregunta de investigación es: «¿Cómo puede la investigación científica contribuir a mejorar las prácticas de seguridad usable en el futuro?» (RQ3). Teniendo en cuenta la importancia de esta cuestión y la aparición de nuevos problemas relacionados con la seguridad debido al rápido desarrollo de las tecnologías, es fundamental identificar áreas en las que se puedan introducir mejoras para mantenerse al día con los retos de ciberseguridad.

Estas preguntas de investigación se formularon con el fin de ayudar a analizar y comparar los resultados científicos, así como a determinar el estado actual de la investigación y las futuras líneas de investigación.

4. Proceso de revisión

El enfoque de nuestra revisión bibliográfica comprende los siguientes pasos:

- Fase 1. Identificación de posibles artículos resultantes de una búsqueda bibliográfica en las bases de datos IEEE y PsycInfo;
- Fase 2. Filtrado de los artículos teniendo en cuenta los criterios de inclusión y exclusión establecidos (véanse las secciones 4.2.1 y 4.2.2);
- Fase 3. Revisión detallada de los artículos seleccionados en los pasos anteriores;
- Fase 4. Análisis de los resultados obtenidos durante la revisión y discusión.

4.1. Fase 1: Estrategia de búsqueda para la identificación de posibles artículos

4.1.1. Bases de datos electrónicas y bibliotecas digitales

Esta primera fase consistió en la búsqueda de artículos en PsycInfo (base de datos electrónica) e IEEE Xplore (bibliotecas digitales) para identificar estudios relevantes. Se realizaron búsquedas en ambas bases de datos el 1 de diciembre de 2022.

- IEEE Xplore (<https://ieeexplore.ieee.org/>, consultado el 1 de diciembre de 2022) ofrece acceso web a más de cinco millones de documentos en texto completo procedentes de algunas de las publicaciones más citadas del mundo en ingeniería eléctrica, informática y electrónica.
- PsycINFO (<https://psycinfo.apa.org/>, consultada el 1 de diciembre de 2022) es una base de datos de resúmenes de artículos de revistas académicas publicados en todos los campos de la psicología a nivel mundial desde principios del siglo XIX. Esta base de datos contiene citas bibliográficas, resúmenes, referencias citadas e información descriptiva.

La elección de estas dos bases de datos se debe al carácter transversal del tema de la seguridad usable, que es objeto de estudio por parte de ingenieros, informáticos y psicólogos.

4.1.2. Procedimiento de búsqueda

Identificamos palabras clave para recopilar nuestro conjunto inicial de artículos. Dado que nuestro objetivo era analizar la bibliografía que aborda el tema de la seguridad usable, se definió una consulta de búsqueda

para seleccionar artículos que mencionaran la seguridad y la usabilidad, teniendo en cuenta también la ciberseguridad, que suele estar estrechamente relacionada con el concepto de seguridad usable. La cadena de búsqueda utilizada para IEEE Xplore es la siguiente: (((«Palabras clave del autor»: usabilidad) O («Palabras clave del autor»: usable)) Y («Palabras clave del autor»: seguridad) O («Palabras clave del autor»: ciberseguridad) O («Palabras clave del autor»: cyber-security)); por otra parte, la cadena de búsqueda para PsycInfo es la siguiente: (KW usability) AND (KW security OR KW cybersecurity OR KW cyber-security).

Se incluyeron en la búsqueda todos los artículos publicados en revistas académicas — excluidas las actas de congresos y los libros— que se publicaron entre 2005 y 2022.

La primera búsqueda arrojó 80 artículos seleccionados tras la lectura de los resúmenes (véase la sección 4.2).

4.2. Fase 2: Selección de estudios

En primer lugar, revisamos los 80 estudios que surgieron de la primera búsqueda. A partir de este análisis inicial, se eliminaron dos artículos, ya que aparecían en ambas búsquedas.

En la siguiente fase, se identificaron los criterios de inclusión y exclusión para evaluar qué artículos eran realmente relevantes para nuestra investigación.

4.2.1. Criterios de inclusión

- Se incluyeron todos los trabajos empíricos relacionados con la relación entre usabilidad y seguridad;
- Los artículos incluidos en la investigación debían utilizar el término «usabilidad», entendido como «el grado en que un producto puede ser utilizado por usuarios específicos para alcanzar objetivos específicos con eficacia, eficiencia y satisfacción en un contexto de uso determinado» (ISO-9241-11:2018);
- Solo se incluyeron artículos escritos en inglés (británico y americano).

4.2.2. Criterios de exclusión

- No se tuvieron en cuenta los artículos de revisión;
- No se incluyeron los artículos escritos en idiomas distintos del inglés;
- Se eliminaron los trabajos que, tras una lectura inicial de los resúmenes y las palabras clave, no investigaban la relación entre la usabilidad o la seguridad;
- El término «usabilidad», cuando se consideraba como «viabilidad» y/o «uso», dio lugar a la exclusión de los artículos en los que se utilizaba de esta forma.

A la luz de los criterios mencionados anteriormente, evaluamos la calidad de cada estudio y analizamos el título, el resumen y las palabras clave. Se descartó un artículo porque no estaba escrito en inglés, mientras que otros 22 no se incluyeron porque no abordaban específicamente la relación entre seguridad y usabilidad. Como resultado, se excluyeron del estudio 23 trabajos que no cumplían los criterios, lo que redujo la búsqueda a 55 estudios (Figura 1).

4.3. Fase 3: Revisión detallada de la bibliografía

El proceso de selección de artículos condujo a una revisión detallada de 55 artículos empíricos publicados en revistas internacionales, excluyendo todas las revisiones y artículos conceptuales que no abordaban el tema de forma experimental. Los artículos trataban varios temas recurrentes y podían clasificarse, a grandes rasgos, en los siguientes:

- Usabilidad de los métodos de autenticación;
- Ayudar a los desarrolladores de seguridad a mejorar la usabilidad;
- Estrategias de diseño para influir en el comportamiento de los usuarios en materia de seguridad;
- Modelos formales para la evaluación de la seguridad usable.

La siguiente sección (véase la sección 4.4) ofrece una visión general de los principales aspectos observados durante la investigación y analiza las diferentes categorías.

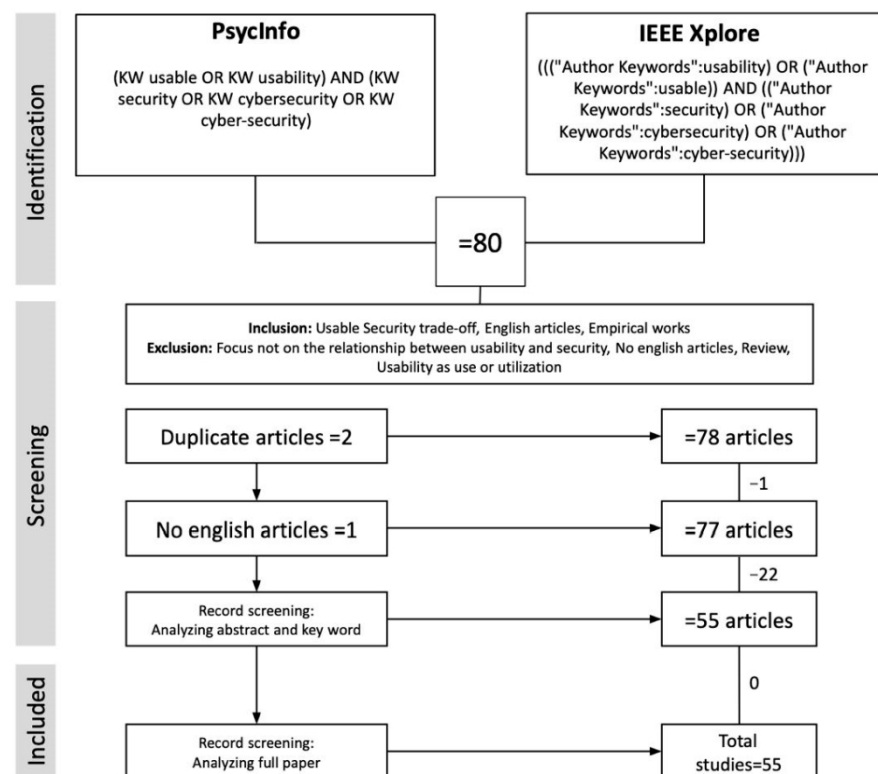


Figura 1. Diagrama de flujo del proceso de revisión con el número de trabajos incluidos y excluidos en cada paso.

4.4. Fase 4: Análisis y agrupación

La «seguridad usable» ha suscitado un interés creciente entre los investigadores a lo largo de los años, como se desprende del creciente número de artículos publicados, especialmente en los últimos años (Figura 2). El mayor número de artículos empíricos publicados sobre el tema se ha registrado en los últimos tres años (2020-2022), mientras que se observa un número mínimo (solo un artículo al año) desde 2005 hasta 2011. Los artículos relacionados con este tema y analizados en esta revisión se publicaron en varias revistas, tanto de psicología como de informática e ingeniería (Tabla 1). En cuanto a la afiliación de los autores, Estados Unidos registró el mayor número de artículos, seguido del Reino Unido (Figura 3).

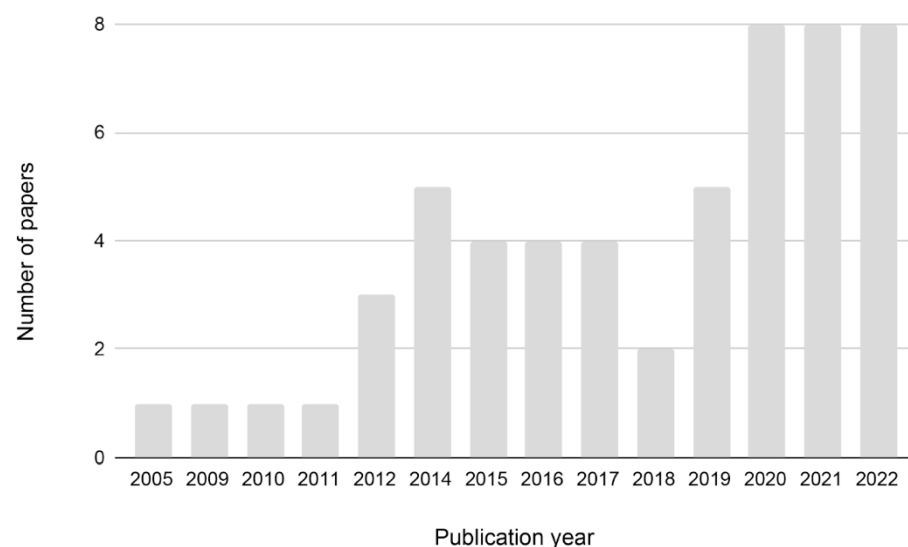
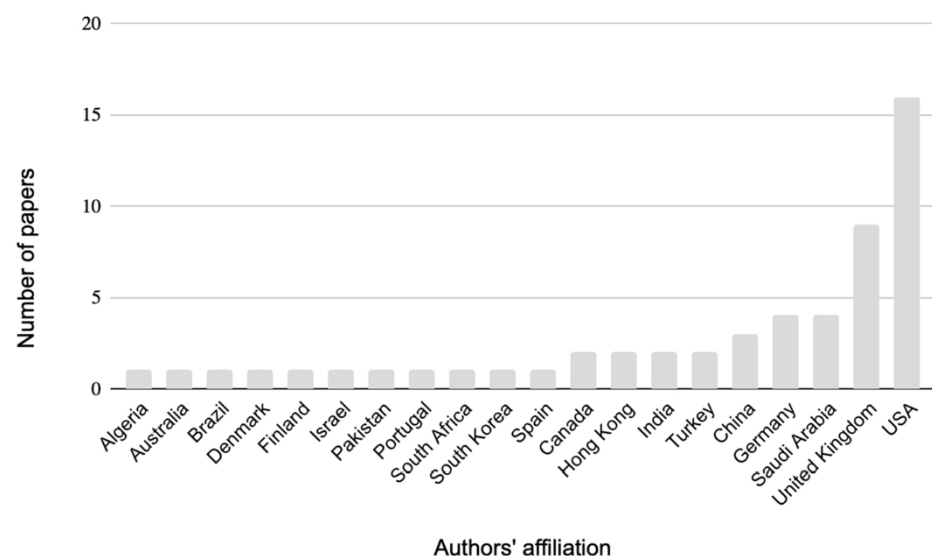


Figura 2. Número de artículos entre 2005 y 2022.

Tabla 1. Revistas de publicación y número de artículos por revista.

Revista	N.º de artículos
International Journal of Human-Computer Studies	8
Behaviour & Information Technology	7
IEEE Access	7
IEEE Transactions on Dependable and Secure Computing	6
IEEE Transactions on Information Forensics and Security	3
Interacción con Ordenadores	3
Factores humanos	2
Transacciones del IEEE sobre Electrónica de Consumo	2
Transacciones del IEEE sobre informática móvil	2
Revista de Ingeniería Cognitiva y Toma de Decisiones	2
Revista Internacional de Tecnología e Interacción Humana	2
Transacciones de la ACM sobre Interacción Persona-Ordenador	1
Ordenadores en el Comportamiento Humano	1
Frontiers in Psychology	1
Revista IEEE sobre el Internet de las cosas	1
Transacciones del IEEE sobre Cibernética	1
Transacciones del IEEE sobre Sistemas Hombre-Máquina	1
Transacciones del IEEE sobre Ingeniería de Software	1
Información y Gestión	1
Investigación en Sistemas de Información	1
Revista Internacional de Interacción Persona-Ordenador	1
Revista Internacional de Interacción Persona-Ordenador Móvil	1

**Figura 3.** Número de artículos publicados en el país de afiliación de los autores.

En la última etapa del proceso de análisis, concretamente el análisis de los artículos completos, se leyeron, resumieron y debatieron 55 artículos. Los artículos se centraron principalmente en cuatro áreas de investigación principales:

- (1) la usabilidad de los métodos de autenticación, (2) cómo ayudar a los desarrolladores de seguridad a mejorar la usabilidad,
- (3) estrategias de diseño para influir en el comportamiento de los usuarios en materia de seguridad, y (4) modelos formales para la evaluación de la

. Los artículos se centraron principalmente en la autenticación, que fue el tema con mayor número de artículos (31), mientras que se prestó menos atención a los demás temas. Las siguientes secciones abordan los grupos identificados.

4.4.1. Usabilidad de los métodos de autenticación (34 artículos)

Los artículos que encajan en esta temática se centran en evaluar la calidad de los sistemas de autenticación, prestando atención principalmente a su eficacia a la hora de frustrar ciberataques, en detrimento de una evaluación exhaustiva de su usabilidad. Por este motivo, el término «seguridad usable» se utiliza aquí de forma errónea, ya que el proceso de evaluación de la usabilidad tiene lugar una vez finalizado el producto, y no durante el proceso de desarrollo. En algunos de los estudios [13], se da por sentada la usabilidad y ni siquiera se evalúa. Además, solo algunos de los artículos revisados tienen en cuenta la satisfacción del usuario para la evaluación de la usabilidad, centrándose casi exclusivamente en el rendimiento. Se trata de una deficiencia significativa, ya que dos artículos muestran que el rendimiento a menudo no es directamente proporcional a la satisfacción [14,15], aunque la satisfacción es una parte integral de la usabilidad. Teniendo en cuenta el gran número de artículos pertenecientes a este grupo (el 56 % de los artículos), se ha considerado oportuno agruparlos a su vez en subgrupos más detallados.

Los subgrupos fueron los siguientes:

- Prueba de Turing pública y totalmente automatizada para distinguir entre ordenadores y humanos (CAPTCHA);
- Alternativas a la contraseña;
- Entornos virtuales;
- Ataques relacionados con la proximidad;
- Evaluación de la usabilidad de sistemas existentes y novedosos.

Prueba de Turing pública y completamente automatizada para distinguir entre ordenadores y humanos (CAPTCHA): Una de las herramientas investigadas son las pruebas CAPTCHA [14,16–20]. CAPTCHA es una medida de seguridad conocida como autenticación de «desafío/respuesta», cuyo objetivo es proteger a los usuarios del spam y del descifrado de contraseñas pidiéndoles que superen una prueba sencilla que demuestre que el usuario es una persona y no un ordenador que intenta piratear una cuenta protegida con contraseña.

Sin embargo, estos estudios pusieron de relieve la disminución de su eficacia a la hora de distinguir entre humanos y máquinas debido a los avances en los algoritmos de aprendizaje automático [19].

El principal objetivo de investigación de estos estudios es aumentar la seguridad de los CAPTCHA, manteniendo al mismo tiempo una usabilidad aceptable para los usuarios humanos. Entre las Pruebas de Interacción Humana (HIP) estudiadas, las basadas exclusivamente en texto demostraron ser más fáciles de usar en comparación con los demás métodos [14,18]. No obstante, la elección de las HIP debe realizarse con cuidado en función de las características de los usuarios, ya que estos pueden percibir las HIP de formas diferentes. Olalere et al., 2014, muestran que los usuarios con discapacidad visual tienen una mayor tasa de éxito a la hora de resolver CAPTCHAs basados en audio en comparación con los usuarios con visión normal. Por el contrario, se ha demostrado que los CAPTCHAs basados en texto resultan más difíciles para los extranjeros [21].

Las variables dependientes más utilizadas en estos estudios están relacionadas con el rendimiento, como la tasa de éxito y el tiempo de resolución de la prueba, dejando a un lado de lado la satisfacción de los usuarios, que es un elemento relevante que contribuye a la usabilidad de una solución.

Alternativas a la contraseña: en los contextos en los que es posible utilizar contraseñas de texto tradicionales, estas son el método preferido por muchos [22]. No obstante, las herramientas alternativas a las contraseñas de texto habituales resultan difíciles de utilizar en algunos contextos y se caracterizan por vulnerabilidades debidas al factor humano. Se analizó la previsibilidad de los patrones [4], sustituyendo a menudo los elementos textuales por otros gráficos [4, 15, 23–25] y basados en el sonido [20].

Algunos han optado por no eliminar las contraseñas textuales creando otras complejas de forma que resulten fáciles de usar. Juang y Greenstein [26] permitieron a los usuarios dibujar escenas que les recordaran contraseñas frasales sin sentido, mientras que Biddle et al. [25] permitieron a los usuarios elegir un objeto digital de su propiedad para generar contraseñas textuales complejas.

Otros han investigado el uso de la ubicación geográfica como método alternativo de autenticación [27, 28], que, según informan, resulta a la vez fácil de usar y seguro.

Por último, Zhang et al. [29] exploraron el concepto de utilizar un dispositivo portátil para la autenticación, en el que los autores integran métodos existentes (contraseña, PIN y huella dactilar), demostrando que este método aumentaría la seguridad de los métodos de autenticación mencionados anteriormente, manteniendo una «alta usabilidad» (sin definir ni cuantificar).

Entornos virtuales: Algunos autores han cuestionado la usabilidad de los modos de autenticación en entornos tecnológicos emergentes, como los de realidad virtual, donde las posibilidades que ofrece el entorno tridimensional pueden determinar un aumento de la seguridad a través de formas de interacción que antes no habrían sido posibles.

Algunos estudios han evaluado sistemas que aprovechan la tercera dimensión para aumentar la seguridad del método de autenticación, al tiempo que intentan mantener la usabilidad [30, 31], mientras que otros se centran más en las entradas complejas que proporcionan los usuarios a través de los sistemas wearables avanzados asociados a estos entornos [30].

Li et al. [32] utilizaron el tiempo de inicio de sesión y el éxito en el inicio de sesión como indicadores de usabilidad. De manera similar, Mathis et al. [30] emplearon el tiempo de inicio de sesión en su estudio, que consistía en la manipulación de un cubo mediante diferentes modalidades, como el tacto, el movimiento de los ojos o el movimiento de la cabeza. Los participantes indicaron sentirse más cómodos (usabilidad) al tocar el controlador, pero se prefirió el uso de la mirada en términos de usabilidad y seguridad. Wazir et al. [31] compararon su método de autenticación 3D con uno ya existente, y observaron una usabilidad similar y una seguridad mejorada.

Ataques relacionados con la proximidad: Otro tema central es evitar los ataques basados en la proximidad de personas malintencionadas, como el «shoulder surfing» y el espionaje. Estos ataques son posibles mediante la recopilación de información visible u audible de un usuario cercano. Por lo tanto, estas soluciones se centran en el uso de parámetros perceptibles únicamente por el usuario [22, 23, 32, 33]. Se ha señalado que los esquemas multimodales son prometedores para la autenticación secundaria, en la que los usuarios se sienten observados o desean proteger datos sensibles [33]. Khan et al. [23] evaluaron una herramienta de autenticación llamada g-RAT basada en un algoritmo de imágenes aleatorias que utiliza dibujos en lugar de números. Informaron de una mayor seguridad frente a los ataques de «shoulder surfing» y de una mejor usabilidad. Se comprobó que el sistema GeoPass de Al-Ameen y Wright [27] no se veía afectado por la forma en que el usuario accedía a la contraseña de ubicación, ya fuera desplazándose por el mapa o escribiendo la dirección completa en la barra de búsqueda. El rendimiento de la autenticación (tiempo, intentos) se utiliza habitualmente para evaluar la usabilidad en todos esos artículos.

Evaluación de la usabilidad de sistemas existentes y novedosos: Las contribuciones pertenecientes a esta categoría parecen caracterizarse por dos enfoques principales a la hora de evaluar los productos o métodos: los autores los evalúan de forma individual [20, 25, 27, 29, 34–37] o los comparan con otros sistemas existentes o nuevos [4, 13–19, 22, 24, 26, 28, 30, 32, 33, 38–41].

En estos artículos suele darse una interpretación errónea del concepto de usabilidad. Por ejemplo, en muchos casos, la usabilidad se reduce a sus componentes de eficiencia y eficacia, evaluándola con parámetros como el tiempo necesario para completar tareas y el número de intentos para completar los procesos de autenticación [15, 16, 18–20, 24, 27, 29, 33, 38]. En ocasiones, la usabilidad no se evaluó, sino que se dio por supuesta [32]. En cuanto a la disyuntiva entre usabilidad y seguridad, los resultados suelen ser dispares. Por ejemplo, algunos estudios señalaron que la usabilidad disminuye a medida que aumenta la seguridad [17], mientras que otros indicaron que una cambiaba mientras que la otra permanecía prácticamente inalterada [16]. Varios artículos carecen de la información necesaria para permitir la replicabilidad de los experimentos.

Por ejemplo, Biddle et al. [25] no indican las preguntas formuladas a los participantes.

Otra cuestión crítica que comparten muchos artículos pertenecientes a este grupo es la creación y el uso de medidas personalizadas para evaluar la usabilidad de los productos y sistemas estudiados, como la longitud del código [15] o el esfuerzo de escritura [39], relacionadas exclusivamente con la herramienta específica utilizada. Esto pone de manifiesto una debilidad metodológica, al prescindir de los estándares de referencia para la evaluación de la usabilidad y hacer que, a menudo, los estudios no sean comparables.

Además, los participantes en los estudios solían ser estudiantes universitarios cuya especialidad se consideraba que tenía poca influencia en los experimentos, cuando, de hecho, este parámetro sí influía en su dominio de la informática. Por último, algunos estudios contaban con usuarios con características especiales: usuarios de dispositivos específicos [31, 36] o con características específicas, como discapacidades visuales [18, 20] y estilos de vida concretos [35].

4.4.2. Ayudar a los desarrolladores de seguridad a mejorar la usabilidad (7 artículos)

Estos artículos están dirigidos a diversos tipos de desarrolladores, desde públicos más amplios, como los desarrolladores web, de navegadores o de sistemas [42,43], hasta públicos más específicos, como los desarrolladores de sistemas de correo electrónico [44], los desarrolladores web noveles [45] o incluso los gestores y los desarrolladores del ámbito académico [46]. Los autores intentaron encontrar una solución que equilibrara la seguridad y la usabilidad, orientando a los desarrolladores que trabajan en diferentes contextos para garantizar una experiencia de usuario cómoda sin comprometer la protección de sus datos e información. En un caso, por ejemplo, analizan la importancia de incluir información relacionada con la seguridad en la documentación de las interfaces de programación de aplicaciones (API) inseguras, las cuales, aunque no estén diseñadas explícitamente con fines de seguridad, pueden suponer un riesgo si no se utilizan correctamente [45].

Gorski et al. [45] llevaron a cabo un experimento con 49 desarrolladores noveles para investigar lo siguiente:

1. ¿En qué medida influye la ubicación de la información relacionada con la seguridad en la documentación de la API en la transmisión de dicha información a los desarrolladores?
2. cómo leen esta documentación, centrándose en los elementos a los que prestan más atención mediante el uso del seguimiento ocular;
3. El impacto de la presencia de instrucciones de ciberseguridad (en este caso, la Política de Seguridad de Contenidos, o CSP) en la documentación de la API sobre la funcionalidad y la seguridad del producto final.

El experimento consistió en completar cuatro tareas de programación. A continuación, los desarrolladores examinados buscaron la solución en la documentación de la API, pero solo tres grupos disponían de una que incluyera instrucciones sobre la CSP. El grupo de control restante contó con la documentación original proporcionada por Google, que carecía de información relacionada con la ciberseguridad.

El experimento demostró que los desarrolladores evaluados seguían estrategias de desarrollo «orientadas al código»: buscaban inmediatamente la solución en las líneas funcionales del código de ejemplo, en lugar de en las partes descriptivas (alejándose de un enfoque «orientado a los conceptos»). Esta dinámica de comportamiento no favoreció a los desarrolladores del grupo de control, quienes, al no encontrar en el documento información útil para resolver el problema, lo resolvieron eliminando directamente el fragmento de código problemático (relacionado con la CSP). Por otro lado, sí favoreció a los del grupo en el que la documentación de la API incluía sugerencias sobre CSP en forma de comentarios en el código que remitían al capítulo específico. Estos fueron más capaces que los demás de resolver el problema haciendo que la parte problemática del código funcionara, creando así un software operativo y seguro.

Aunque los desarrolladores del grupo de control crearon soluciones que funcionaban, ninguna de ellas estaba protegida por CSP (un candidato llegó incluso a comentar: «Dejemos la seguridad de lado por ahora»), mientras que la mayoría de las soluciones desarrolladas por los candidatos de los otros grupos sí estaban protegidas. Los autores sostienen que la mejor estrategia para llamar la atención de los desarrolladores sobre estas indicaciones transversales, percibidas como secundarias, es situarlas cerca de los ejemplos de código más funcionales, que son lo primero que consultan los desarrolladores cuando tienen dificultades.

A continuación, sugieren que los proveedores de bibliotecas ofrezcan cadenas de código CSP a medida junto con su servicio.

En otro artículo, los autores exploraron el papel de las interfaces gráficas de usuario (GUI) en la gestión de la configuración de seguridad y privacidad en las redes sociales [47]. Los autores describen una serie de modelos de seguridad para ayudar a los desarrolladores de redes sociales a diseñar entornos interactivos que protejan la privacidad y la seguridad de las personas, sin dejar de ser extremadamente fáciles de usar. A continuación, se llevaron a cabo experimentos para comprobar la eficacia de los modelos propuestos y comparar las interfaces gráficas de usuario de dichos modelos con las que se utilizan actualmente en Facebook. Se estructuraron cuatro tareas: tarea de solicitud de aplicación, tarea de solicitud de amistad, tarea de compartir fotos y tarea de lista de amigos. Para cada tarea, se analizaron los siguientes factores: satisfacción del usuario, facilidad de aprendizaje, actitudes, interactividad y privacidad, y se pidió a los participantes que otorgaran una puntuación en una escala de Likert (del 1 al 5).

Los resultados del estudio mostraron, en primer lugar, un gran interés por parte de los usuarios en proteger su información personal. En segundo lugar, se observó que, en todas las tareas, los participantes preferían utilizar las interfaces gráficas de usuario propuestas por los distintos modelos en lugar de las propuestas por Facebook, que resultaban más complejas y ofrecían menos opciones relacionadas con la seguridad. Por lo tanto, los modelos propuestos

proporcionan a los usuarios de las redes sociales una retroalimentación adecuada e interfaces de usuario eficaces que les ayudan a tomar sus decisiones en materia de seguridad y privacidad, y tratan de lograr un equilibrio entre la usabilidad y la seguridad.

Por otra parte, dos artículos se centran en investigar cómo integrar de forma eficaz la seguridad y la usabilidad en el diseño y la implementación de sistemas de correo electrónico para evitar que los usuarios sean víctimas de ataques de phishing [43, 44]. A pesar de compartir el mismo ámbito de investigación, los estudios emplearon metodologías totalmente diferentes. En el estudio de Alsharnouby et al. [43], se mostró a los participantes una serie de sitios web y se les pidió que identificaran los sitios de phishing. Mediante el análisis de los movimientos oculares, los autores evaluaron el éxito de los participantes a la hora de identificar sitios web fraudulentos, el tiempo que dedicaban a observar diferentes aspectos de la pantalla y el razonamiento que seguía su toma de decisiones. Los autores identificaron varios tipos de amenazas y, para cada tipo, investigaron la capacidad de los participantes para identificar el sitio malicioso: (1) Sitio web falsificado con una URL incorrecta: en general, a los participantes les costó identificar los sitios web bancarios fraudulentos y no reconocieron las URL incorrectas. Sin embargo, identificaron correctamente el sitio web del Gobierno canadiense que les pedía que se inscribieran en un servicio de protección contra el robo de identidad. (2) Sitio web falso con una dirección IP en la URL: solo el 38 % de los participantes reconoció que el sitio web de PayPal tenía una dirección IP en lugar de una URL y lo consideró sospechoso. (3) Chrome falso: solo el 62 % de los participantes reconoció que un sitio web era un intento de phishing. (4) Ventanas emergentes que solicitaban credenciales: el 38 % de los participantes cayó en la trampa. (5) Ventanas emergentes superpuestas: el 62 % de los participantes reconoció el sitio de phishing superpuesto, a pesar de que se veía una doble URL. (6) Fraude basado en el contexto: el 95 % de los participantes reconoció correctamente el «Credit Card Checker» como un sitio de phishing, probablemente debido a la concienciación mediática. (7) Sitios web legítimos: los participantes alcanzaron altas tasas de éxito en el reconocimiento de sitios web legítimos, lo que pone de relieve su capacidad para distinguir lo que parece «normal» de lo que resulta sospechoso.

En el artículo de Roth et al. [44], se realizan entrevistas a 19 usuarios para presentar un enfoque de diseño innovador para el correo electrónico seguro no intrusivo, centrándose en el equilibrio entre seguridad y usabilidad para un grupo específico de usuarios (usuarios de correo electrónico privado no comercial). El enfoque se ajusta estrechamente a los principios de ingeniería establecidos para el diseño de mecanismos de protección, con el objetivo de que el diseño sea lo más sencillo y ligero posible. Evita componentes complejos como las infraestructuras de clave pública o la «Web of Trust» y separa el intercambio de claves de la vinculación de estas a las identidades, lo que permite a los usuarios equilibrar la usabilidad y la seguridad. El diseño se ajusta a los principios de simplicidad, valores predeterminados a prueba de fallos y facilidad de uso. El cifrado del correo es automático y transparente, lo que minimiza la interacción del usuario. El diseño ofrece metáforas de interacción familiares y permite a los usuarios aumentar la seguridad basándose en sus estadísticas de comunicación por correo, optimizando así la utilidad de la seguridad. El enfoque se ajusta a prácticas de diseño prudentes y cuestiona la necesidad de infraestructuras de certificación para usuarios privados y no comerciales. Los autores sugieren tres líneas prometedoras para futuras investigaciones: mejorar la interacción persona-ordenador para una verificación de claves fácil de usar, desarrollar mejores métricas para maximizar la seguridad por interacción y enfoques innovadores para incentivar los esfuerzos de seguridad en las interfaces de usuario, promoviendo así un nivel básico de protección del correo.

El trabajo de Flechais y Sasse [42] aborda una cuestión más específica, al intentar analizar el problema de la disyuntiva en relación con la e-ciencia. La e-ciencia es una plataforma que proporciona a numerosos usuarios acceso a valiosos recursos computacionales, datos y software. Una atención insuficiente a la seguridad puede dar lugar a ciberataques que obstaculicen el objetivo de la e-ciencia, que es permitir la utilización de los recursos que ofrece. La investigación presentada en este artículo se basa en cuatro estudios de caso de proyectos de e-ciencia. Los autores analizaron transcripciones y presentaron un modelo que describe los factores generales a tener en cuenta y los problemas identificados durante el diseño de la seguridad. Mediante el uso de la herramienta ATLAS.ti, se codificó la información, identificándose cuatro categorías: motivación, responsabilidad, comunicación y partes interesadas. Tal y como ponen de relieve los estudios de caso, lo que se desprende es que la participación de las partes interesadas en el diseño de la seguridad constituye un medio muy eficaz para identificar sus necesidades. Además, la presencia de las partes interesadas durante el diseño de la seguridad también ofrece beneficios adicionales a la hora de aumentar la concienciación y el conocimiento sobre las cuestiones de seguridad del sistema.

En cuanto a los factores identificados, la motivación y la responsabilidad son dos aspectos clave que trascienden el ámbito de una metodología de diseño. La asignación de responsabilidades también influye en la motivación de las partes interesadas, aumentándola notablemente entre los responsables de la seguridad. Además, el proceso de diseño de la seguridad debe ser participativo, inclusivo y comprensible para todos los participantes. Por otra parte, uno de los elementos clave de cualquier ejercicio de diseño es garantizar una buena comunicación entre los participantes. Los métodos de seguridad que adoptan y se basan en escenarios se ajustan mucho más a la forma en que las personas suelen comunicarse sobre la seguridad.

El artículo de Dhillon et al. [46] tiene como objetivo identificar objetivos basados en valores para decidir el equilibrio entre seguridad y usabilidad. Este enfoque es muy pragmático, ya que busca traducir conceptos abstractos en criterios medibles y evaluables. Tras varias fases en las que se analizaron y redujeron los objetivos mediante entrevistas y análisis estadísticos, los autores identificaron cuatro objetivos finales: maximizar la facilidad de uso y mejorar la comunicación relacionada con el sistema, maximizar la estandarización y la integración, y maximizar la capacidad del sistema. Según los autores, estos objetivos resultan útiles para orientar la implementación y el desarrollo de software.

Los artículos mencionados pretenden ofrecer perspectivas sobre cómo abordar esta cuestión, y todos coinciden en que es necesario salvar esta brecha mediante diversas estrategias, que van desde aspectos más técnicos —como la ubicación precisa de la información de seguridad para hacerla más visible a los desarrolladores [45]— hasta aspectos más generales, como consejos sobre la simplicidad del diseño para que resulte más accesible a los usuarios.

El análisis de los artículos de esta categoría ha planteado cuestiones importantes sobre la metodología empleada y los contenidos tratados. En particular, resulta evidente la falta de una metodología común que permita replicar los estudios y establecer un enfoque estandarizado para abordar la cuestión en cuestión.

La reflexión más importante se refiere a las conclusiones extraídas en estos artículos: aunque su objetivo es servir de orientación a los desarrolladores, ofreciéndoles directrices sobre cómo abordar la cuestión durante la fase de diseño, a menudo las recomendaciones proporcionadas son generales y no parecen basarse en un trabajo empírico genuino. En algunos estudios, las recomendaciones se asemejan a reflexiones sobre aspectos «organizativos», tales como: (1) la necesidad de asignar responsabilidades específicas a cada parte interesada para aumentar su motivación y evitar la dispersión de responsabilidades; (2) comprender las motivaciones que subyacen a la necesidad de seguridad; (3) el proceso de diseño de seguridad debe ser participativo, inclusivo y comprensible para todos los participantes; (4) identificar anécdotas y escenarios relacionados con la seguridad [42]. En otros estudios, las recomendaciones son muy generales y se centran en la facilidad de uso más que en la usabilidad [44], instando a los desarrolladores a concentrarse en integrar las interfaces gráficas de usuario (GUI) con los aspectos de seguridad para crear una GUI fácil de usar [43, 47]. Sin embargo, sigue sin estar claro qué significa simplificar el diseño para que las GUI sean más fáciles de usar. Los desarrolladores necesitarían información más detallada y concreta sobre qué aspectos deben tener en cuenta. Alsharnouby et al. [43] intentan ofrecer recomendaciones más específicas, como (1) hacer que el ámbito resulte más evidente, (2) proporcionar una vista previa para observar los cambios y (3) trasladar algunas operaciones directamente a Chrome, aunque estos aspectos no se derivan de un trabajo empírico sistemático.

Por otra parte, el estudio de Gorsky et al. [45] parece ofrecer recomendaciones más técnicas, como (1) colocar instrucciones transversales cerca de los ejemplos de código más funcionales, que suelen ser lo primero que consultan los desarrolladores cuando se enfrentan a dificultades; (2) proporcionar fragmentos de código CSP personalizados a los proveedores de bibliotecas para su servicio.

Este conjunto de trabajos tiene como objetivo aportar ideas valiosas sobre el diseño de sistemas seguros. Sin embargo, también subraya la necesidad de un mayor rigor metodológico y de una mayor especificidad en las recomendaciones proporcionadas a los desarrolladores.

4.4.3. Estrategias de diseño para influir en el comportamiento de los usuarios en materia de seguridad (10 artículos)

Este es, con diferencia, el grupo más interesante para nuestros objetivos. Varios trabajos de este grupo han abordado la disyuntiva entre usabilidad y seguridad de diversas maneras. Por ejemplo,

Merdenyan y Petrie [48] intentaron comprender si ciertos comportamientos inseguros relacionados con el uso de contraseñas (como guardarlas, compartirlas y reutilizarlas) se debían a una subestimación de los riesgos o a una sobreestimación de los beneficios. En un estudio correlacional realizado con una muestra reclutada a través de la plataforma MTurk, los autores demostraron que estas dos dimensiones tenían efectos diversos sobre la probabilidad de adoptar comportamientos específicos. Por ejemplo, el componente más crucial en relación con la reutilización de contraseñas era el beneficio percibido derivado de esta práctica, una vez descontados los riesgos asociados. Esto sugiere que las intervenciones de comunicación y formación deberían centrarse en aspectos diversos, dependiendo del comportamiento que se pretenda modificar. Sin embargo, cabe señalar que este estudio no investigó los comportamientos reales de los participantes, sino más bien la probabilidad que estos declararon de adoptar dichos comportamientos.

Del mismo modo, Haque et al. [49] exploraron el tema de la reutilización de contraseñas, demostrando que los usuarios se basan en una jerarquía de importancia de las contraseñas según el tipo de sitio web. Los autores distinguen entre cuentas de «identidad» (p. ej., correo electrónico, redes sociales), cuentas «financieras» (p. ej., banca en línea), cuentas de «contenido» (p. ej., servicios personalizados como sitios web meteorológicos) y cuentas «dudosas» (p. ej., sitios de descuentos y promociones). A los sitios «financieros» se les atribuye mayor importancia (incluso mayor que a las cuentas de «identidad») y, por lo tanto, los usuarios ponen mayor cuidado al crear las contraseñas asociadas. Sin embargo, las contraseñas generadas para otros sitios menos importantes suelen presentar similitudes semánticas con las elegidas para cuentas más críticas, lo que facilita descifrar contraseñas de alto valor partiendo de otras de menor valor utilizadas en sitios que, presumiblemente, implementan sistemas de protección menos eficaces. En un estudio experimental en el que se pidió a 80 estudiantes que generaran contraseñas para diversos tipos de sitios web, los autores pudieron deducir hasta un 20 % de las contraseñas de alto nivel a partir de las de bajo nivel utilizando una herramienta muy conocida (John The Ripper).

Hirschprung et al. [50] abordaron el tema de la alfabetización tecnológica, que se refiere a la capacidad de utilizar, gestionar, comprender y evaluar la tecnología. Esta habilidad ayuda a los usuarios a decidir cómo equilibrar la usabilidad y la seguridad. Por ejemplo, conocer los riesgos asociados al almacenamiento de contraseñas en el navegador podría disuadir a los usuarios de emplear este procedimiento (considerado ventajoso por el usuario) en sitios web específicos, como los relacionados con la banca en línea. Los autores propusieron una metodología para optimizar el proceso de aprendizaje basada en retos específicos (breves videos informativos) que muestran cómo los piratas informáticos pueden acceder a la información de las tarjetas de crédito guardada en el navegador. Estos retos deberían proporcionar a los usuarios conocimientos que puedan generalizarse a otros casos relacionados. Aunque no son concluyentes, los resultados de su estudio (realizado con una muestra reclutada a través de la plataforma MTurk) animan a adoptar la estrategia que propusieron, ya que un nivel general de alfabetización no es un buen indicador de la capacidad para hacer frente a amenazas específicas de seguridad y privacidad.

A diferencia de estudios anteriores, Steinbart et al. [2] abordaron la cuestión del equilibrio entre usabilidad y seguridad demostrando que el uso de diferentes dispositivos de entrada (teclado de ordenador frente a teclado virtual en un smartphone) puede modificar los comportamientos de seguridad. Dado que es fácil cometer errores al utilizar el teclado virtual de un smartphone, resulta complicado adoptar precauciones para garantizar la seguridad (como contraseñas o frases de acceso más seguras, que al mismo tiempo aumentan la probabilidad de cometer errores de introducción de datos). Hoy en día, estas cuestiones se abordan mediante métodos de autenticación biométrica, como el reconocimiento de huellas dactilares o facial. Sin embargo, el uso de estos métodos de autenticación representa una respuesta a las diferencias de usabilidad de las interfaces de usuario. El estudio se llevó a cabo con una amplia muestra que interactuó de manera efectiva con un sistema en ambos modos, y los autores obtuvieron la autorización del Comité de Ética Institucional (IRB) para evitar el consentimiento informado, que podría inducir efectos de priming al proporcionar demasiada información sobre el estudio. Este aspecto es especialmente relevante y plantea la cuestión de la divulgación de información sobre experimentos en el ámbito de la ciberseguridad, lo que a menudo socava el esfuerzo de investigación por cumplir con las políticas relativas a la experimentación con sujetos humanos. Los participantes en estudios de ciberseguridad deben percibir que la seguridad de la información está realmente en peligro para que el fenómeno pueda investigarse de forma genuina.

Otros estudios del grupo han investigado los efectos de lo que podríamos definir como «usabilidad de la información» en la seguridad. En concreto, se ha identificado un problema significativo

en los permisos que las aplicaciones solicitan a los usuarios, lo que las hace menos seguras y expone a los usuarios a compartir información (por ejemplo, la ubicación o el acceso a la cámara) que a menudo no guarda relación con la funcionalidad de la aplicación. Estas aplicaciones tienen «privilegios excesivos» y pueden dar lugar a problemas de seguridad y privacidad. Aunque los usuarios suelen poder elegir qué permisos conceder, solo algunos tienen la capacidad o el interés para hacerlo. A menudo, las personas eligen las aplicaciones basándose en las valoraciones y la confianza que inspira la descripción de la aplicación.

Gopavaram et al. [51] llevaron a cabo un experimento utilizando información visual (un valor numérico junto al icono del candado) e información auditiva (sonidos alegres y graves, típicamente asociados a respuestas correctas e incorrectas) para indicar los posibles riesgos para la privacidad asociados a la descarga de determinadas aplicaciones. Los participantes fueron reclutados a través de la plataforma MTurk. Los resultados mostraron que quienes fueron expuestos a este sistema integrado eran más propensos a elegir aplicaciones con puntuaciones de privacidad más altas que los grupos de control expuestos a un único indicador o a ningún indicador. Estos hallazgos sugieren el uso de estrategias específicas para dirigir la atención del usuario hacia los permisos que requieren las aplicaciones. Lamentablemente, los autores no abordan la diferente naturaleza de los dos indicadores. Concretamente, la advertencia auditiva es una respuesta que se proporciona inmediatamente después de seleccionar la aplicación (por lo tanto, una consecuencia) y antes de decidir instalarla. Un sonido grave (normalmente asociado a una respuesta incorrecta) podría orientar la atención del usuario hacia la puntuación de privacidad (indicador visual) que, de otro modo, pasaría desapercibida. Esta interpretación es coherente con el principio de refuerzo en el análisis conductual.

Siguiendo con el mismo tema, Gates et al. [52] y Chen et al. [53] sugirieron que, al proporcionar información resumida sobre la seguridad o los riesgos asociados a las aplicaciones, esta debería presentarse como una «puntuación de seguridad» en lugar de una «puntuación de riesgo». Además, la exposición a indicadores de seguridad de las aplicaciones modifica la concienciación de los usuarios, lo que les lleva a buscar activamente esta información incluso en plataformas que no proporcionan el indicador resumido. Estos autores han demostrado que, para mejorar la toma de decisiones, el uso de un enfoque positivo basado en la seguridad es más eficaz que un enfoque negativo basado en los riesgos. Los resultados de sus estudios han indicado que las valoraciones de los usuarios (a menudo expresadas en forma de estrellas) y el enfoque positivo influyen en las decisiones de los usuarios. Sin embargo, cabe señalar que un número significativo de sujetos del estudio de Chen et al. (2015) afirmaron no comprender la puntuación de seguridad/riesgo presentada en forma de círculos de colores, y los análisis posteriores realizados excluyendo los datos de estos sujetos revelaron efectos mucho más débiles. Esto suscita dudas sobre los experimentos llevados a cabo a través de MTurk (una plataforma ampliamente utilizada en este tipo de investigación) y, en particular, sobre la fiabilidad de las respuestas proporcionadas por los participantes.

Por otra parte, Wu et al. [54] abordaron la cuestión de la eficacia de las notificaciones de seguridad móvil (MSN) en los dispositivos móviles, que son notificaciones push ampliamente utilizadas para alertar a los usuarios, pero que también pueden suponer una interrupción de la tarea principal, lo que a menudo da lugar a que se ignoren o se desactiven. En un estudio que utilizó dos tipos de actividades, una «utilitaria» (leer) y otra «hedónica» (jugar a un juego), los autores enviaron MSN con distintos niveles de interrupción. En un caso, la notificación aparecía como una ventana emergente que obligaba al usuario a realizar una acción, interrumpiendo el flujo. Por el contrario, en el otro, la notificación era un banner semitransparente que permitía continuar con la tarea principal. Los resultados mostraron que la irritación causada por la interrupción de la tarea principal no afectaba a la intención de seguir utilizando la aplicación. Sin embargo, este estudio utilizó dos modos de interrupción diferentes en cuanto a presentación y contenido: una ventana emergente indicaba un alto nivel de peligro, mientras que un banner semitransparente indicaba un bajo nivel de peligro. Esto introduce un factor de confusión de cierta importancia.

Por último, algunos trabajos de este grupo se han centrado en el importante tema de los pagos electrónicos. Por ejemplo, Alshamsi y Andras [55] investigaron las percepciones de usabilidad y seguridad respecto al Bitcoin en comparación con las tarjetas de pago tradicionales, demostrando que estas últimas se percibían como más fáciles de usar y seguras. Aunque el estudio no se diseñó para explorar la relación entre estos dos aspectos, los autores sugieren que la percepción de la usabilidad influye en la percepción de la seguridad.

La contribución de Zhang y Luximon [56] resulta más interesante y compleja. Compararon dos sistemas de pagos electrónicos. Ambos sistemas eran idénticos, salvo que uno proporcionaba información sobre: (1) el estado del pago, (2) las identidades de las personas implicadas en la transacción y (3) los riesgos potenciales durante la transacción. En su estudio, los autores manipularon la presencia del beneficiario (físicamente presente o a distancia) y el nivel de confianza (beneficiario conocido o desconocido). Los resultados del estudio mostraron que la información de retroalimentación no influyó en los comportamientos de seguridad de los participantes (como modificar la configuración de la aplicación para mejorar la seguridad y la privacidad). Sin embargo, sí influyó en la percepción de seguridad. Por otra parte, los comportamientos de seguridad aumentaron significativamente en situaciones de baja presencia y baja confianza.

4.4.4. Modelos formales para la evaluación de la seguridad usable (4 artículos)

Entre los artículos que hemos analizado, solo unos pocos se centraron en un aspecto concreto: el desarrollo de modelos de seguridad usables. En un caso, Mohamed et al. [57] propusieron un metamodelo basado en la bibliografía existente para salvar la brecha entre los modelos mentales del usuario y los del diseñador. El objetivo era garantizar que el sistema se ajustara a las expectativas del usuario sobre cómo debería funcionar. Sin embargo, cabe señalar que este metamodelo propuesto es bastante vago y difícil de implementar. Sorprendentemente, ni los autores ni otros grupos de investigación han intentado aplicarlo en estudios posteriores.

Por otra parte, otros tres trabajos de Al-Zahrani [58] y Kumar et al. [1,59] se aventuraron a desarrollar métodos de estimación. Estos métodos tenían como objetivo evaluar la importancia de diversos atributos de usabilidad y seguridad recabando la opinión de las partes interesadas. Estos métodos de estimación emplean la lógica difusa y técnicas relacionadas, basándose en la idea de que la solución elegida debe lograr un equilibrio entre estar lo más cerca posible de la solución positiva ideal y lo más lejos posible de la solución negativa ideal. En esencia, estos modelos intentan establecer prioridades mediante la clasificación y ponderación de diferentes atributos. Sin embargo, estos marcos son bastante complejos y parecen algo desconectados de las prácticas cotidianas de los diseñadores y desarrolladores. En la práctica, plantean dificultades en cuanto a su implementación real.

5. Discusión

El primer objetivo de esta revisión sistemática fue examinar a fondo la investigación empírica existente sobre la intrincada interacción entre la usabilidad y la seguridad, un campo interdisciplinar conocido comúnmente como «seguridad usable» (RQ1). Esta intersección suele implicar un delicado equilibrio: el aumento de las medidas de seguridad a menudo da lugar a una complejidad que dificulta la usabilidad, mientras que los sistemas fáciles de usar pueden comprometer la integridad de la seguridad. Esta dinámica plantea retos significativos desde una perspectiva organizativa.

Las contribuciones analizadas revelaron cómo la compleja relación entre la usabilidad y la seguridad plantea importantes preocupaciones. Los empleados suelen tener dificultades para cumplir con protocolos de seguridad complejos y pueden recurrir a eludirlos cuando se les presenta la oportunidad. Una revisión minuciosa de la bibliografía reveló un panorama rico y diverso de estudios. La segunda pregunta de investigación se centró en la clasificación de estas diferentes contribuciones (RQ2). Los estudios se han clasificado, a grandes rasgos, en cuatro grupos principales, cada uno de los cuales aborda diferentes aspectos:

1. Usabilidad de los métodos de autenticación: Estos artículos tienen como objetivo evaluar la usabilidad de las herramientas de autenticación, ya sea analizándolas de forma independiente o comparándolas con herramientas similares. Se han dividido a su vez en subgrupos: CAPTCHA, alternativas a las contraseñas, entornos virtuales y ataques relacionados con la proximidad.
2. Ayudar a los desarrolladores de seguridad a mejorar la usabilidad: Los artículos de esta categoría se refieren a estudios que tienen como objetivo proporcionar orientaciones a diferentes tipos de desarrolladores para implementar la usabilidad de los sistemas sin reducir el nivel de seguridad.
3. Estrategias de diseño para influir en el comportamiento de los usuarios en materia de seguridad: Este grupo incluye estudios que examinan el equilibrio entre la usabilidad y la seguridad en el uso de la tecnología. Se centra principalmente en el comportamiento individual y en los factores que influyen en la adopción de

comportamientos seguros o inseguros. Los estudios abarcan diversas áreas, entre las que se incluyen los comportamientos relacionados con las contraseñas, la alfabetización tecnológica, el uso de dispositivos de entrada, los permisos de las aplicaciones, los indicadores de seguridad, las notificaciones de seguridad en dispositivos móviles y los sistemas de pago electrónico.

4. Modelos formales para la evaluación de la seguridad usable: Este grupo incluye artículos que han intentado desarrollar modelos de seguridad usables, ya sea ideando un metamodelo para alinear los modelos mentales de los usuarios y los diseñadores con el fin de garantizar la coherencia del sistema, o desarrollando métodos de estimación de los atributos de usabilidad y seguridad mediante lógica difusa y técnicas de agregación (Figura 4).

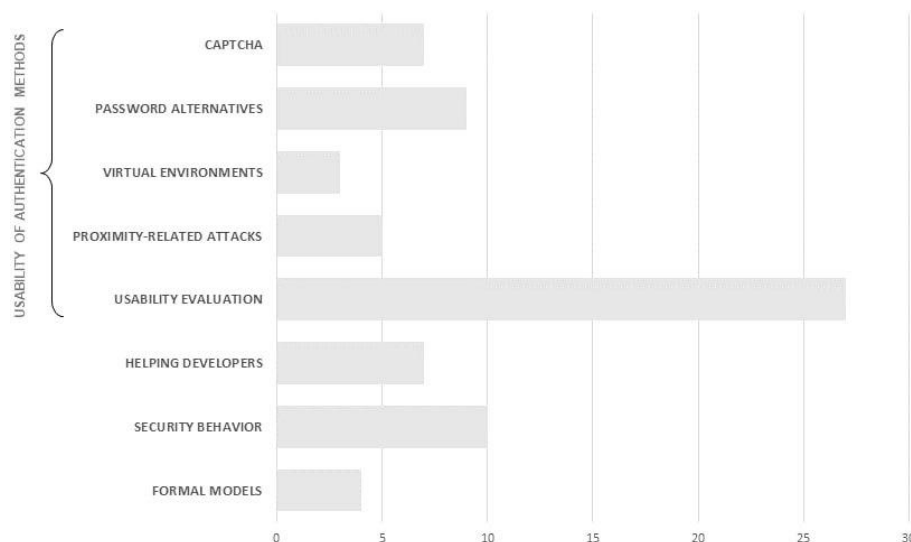


Figura 4. Objetivos de investigación de los artículos revisados (tenga en cuenta que algunos artículos pueden pertenecer a más de una categoría).

La pregunta de investigación final que aborda este artículo es cómo la investigación científica puede contribuir al desarrollo futuro de las prácticas de seguridad usable (QR3). Diversos estudios han demostrado que no existe una forma estandarizada de abordar esta cuestión, lo que requiere un mayor esfuerzo en el futuro para identificar directrices basadas en la evidencia empírica que puedan adoptar tanto los desarrolladores como los usuarios. Además, el trabajo muestra cómo existe una tendencia a querer reducir la brecha entre la usabilidad y la seguridad en lugar de explorarla y aprovecharla, centrando la atención en el comportamiento del usuario. Por el contrario,

Di Nocera y Tempestini [60] intentaron recientemente resolver la cuestión de la disyuntiva proponiendo aprovechar este compromiso en lugar de combatirlo. En concreto, en un estudio de caso único en el que una persona discriminaba entre correos electrónicos sospechosos y no sospechosos, introdujeron una característica de usabilidad como refuerzo para un comportamiento seguro. Los resultados mostraron una mayor sensibilidad (mejor rendimiento) durante la fase de refuerzo en comparación con la línea de base. Por supuesto, esto no es más que un ejemplo de cómo podría abordarse la cuestión. No obstante, la falta de un marco teórico y metodológico común es una de las principales carencias de esta área de investigación.

Nuestra revisión presenta ciertas limitaciones. Para empezar, solo utilizamos dos bases de datos: IEEE Xplore y PsycInfo. Reconocemos la existencia de numerosas bases de datos que indexan artículos relacionados con la seguridad usable. Sin embargo, la elección del número de bases de datos para una revisión bibliográfica sistemática depende del enfoque específico de la revisión y de la disponibilidad de bases de datos pertinentes. Optamos por PsycInfo e IEEE Xplore debido al carácter interdisciplinar del tema de la seguridad usable, que atrae contribuciones de ingenieros, informáticos y psicólogos. Si bien la inclusión de bases de datos adicionales reduciría el riesgo de pasar por alto estudios relevantes, las bases de datos seleccionadas, a saber, IEEE Xplore (1.700 revistas) y APA PsycInfo (2.319 revistas), abarcan todas las revistas pertinentes. Además, aumentar el número de bases de datos consultadas puede dar lugar a la recuperación de más entradas duplicadas.

De acuerdo con la práctica establecida, hemos limitado la revisión sistemática a los artículos publicados en revistas académicas. Sin embargo, esta área de estudio encuentra un espacio editorial privilegiado en las actas de congresos y, por lo tanto, es posible que nuestra selección no refleje plenamente la complejidad de este ámbito. Consideremos, por ejemplo, los estudios de Bravo Lillo et al. [61,62], que examinaron el efecto de habituación en los cuadros de diálogo de seguridad. Este fenómeno revela que los usuarios tienden a pasar por alto mensajes cruciales cuando se encuentran repetidamente con estos cuadros de diálogo. Su respuesta suele volverse automática, lo que les lleva a pulsar un botón para indicar que han tomado nota de la advertencia. Lamentablemente, este comportamiento se produce sin comprender la información contextual que se presenta. Estos estudios han demostrado que unas medidas de seguridad eficaces requieren no solo notificar a los usuarios, sino también una consideración más profunda de muchos aspectos (por ejemplo, los hábitos y los procesos cognitivos). Por lo tanto, los hallazgos de Bravo Lillo siguen siendo relevantes para el diseño de funciones de seguridad que promuevan y garanticen verdaderamente comportamientos seguros por parte de los usuarios. Descuidar estas aportaciones puede limitar la exhaustividad de cualquier debate sobre la seguridad usable. Por otra parte, una revisión sistemática basada en contribuciones a congresos presenta cifras desmesuradas y, aunque muchos artículos de congresos son revisados por pares, ofrecen un nivel de garantía de rigor diferente al de los artículos que han sido sometidos a un proceso de selección más riguroso.

Además, solo hemos incluido trabajos que utilizaran términos relacionados con la usabilidad y la seguridad como palabras clave (es decir, «usable», «usabilidad», «seguridad», «ciberseguridad» y «cyber-security»). Sin embargo, otros artículos que se centran en el estudio del comportamiento de los usuarios en relación con cuestiones de seguridad pueden resultar incluso más relevantes, aunque no utilicen el término «usabilidad» ni lo estudien como tal. Por ejemplo, Hartwig y Reuter [35] han comparado recientemente la eficacia de dos tipos de medidores de contraseñas (un medidor de contraseñas convencional y un gráfico de radar) que ofrecen distintos niveles de detalle sobre la solidez de una contraseña recién creada. Aunque no han enmarcado su investigación en términos de «seguridad usable», su estudio se basa en la retroalimentación visual para respaldar las decisiones en situaciones críticas o señalar información relevante (una estrategia bastante habitual en el diseño centrado en el usuario). Otro estudio reciente, en el que no aparece el término «seguridad» entre sus palabras clave, es la investigación llevada a cabo por Bhana y Flowerday [63]. En su investigación, los autores exploraron la usabilidad del proceso de autenticación de inicio de sesión mediante un análisis comparativo entre contraseñas y frases de contraseña. Introdujeron frases de contraseña que excluyen combinaciones de minúsculas, mayúsculas, dígitos y caracteres especiales. Su investigación analiza cómo las frases de contraseña ofrecen un mayor apoyo a los usuarios a lo largo del proceso de autenticación, abordando cuestiones de seguridad, memoria y escritura. Consideramos que contribuciones como estas son plenamente representativas del campo de la investigación sobre seguridad usable. Sin embargo, el proceso de selección de este tipo de artículos no es sencillo, y el número de artículos que habría que revisar aumentaría rápidamente, lo que haría que dicha selección no fuera viable en el contexto de una revisión sistemática. No obstante, una revisión narrativa podría beneficiarse de una mayor variedad al incluir contribuciones relevantes que no han sido incluidas aquí.

6. Conclusiones

A partir de esta revisión bibliográfica, podemos afirmar que el término «seguridad usable» se utiliza a menudo de forma imprecisa. Con frecuencia, abarca consideraciones generales de usabilidad relacionadas con los sistemas de seguridad, en lugar de definir con precisión estrategias destinadas a perfeccionar la usabilidad de componentes de seguridad específicos. Como resultado, el estado actual de este campo revela cierta inmadurez, ya que los estudios tienden a centrarse en comparaciones entre sistemas, en lugar de establecer directrices de diseño sólidas basadas en un análisis exhaustivo del comportamiento de los usuarios.

En concreto, en el contexto de los sistemas de autenticación, la noción de usabilidad suele girar en torno a métricas de eficacia y eficiencia, dejando de lado aspectos críticos como la satisfacción del usuario —un factor primordial en situaciones reales—. También cabe señalar que muchos de estos estudios se basan en muestras procedentes de plataformas como Amazon Mechanical Turk (mTurk). Si bien estas plataformas ofrecen accesibilidad, las tareas asignadas suelen estar alejadas de los retos reales a los que se enfrentan las personas en sus entornos de trabajo.

Como nota final, una parte significativa de los artículos se centró en los desarrolladores, y creemos que esta actividad de investigación específica es estratégica para una agenda de investigación sobre seguridad usable.

Quienes participan en el diseño y el desarrollo de software influyen en gran medida en la implementación de la seguridad y, en consecuencia, en si esta se implementa de forma usable. En este sentido, Gutfleish et al. [64], en una serie de 25 entrevistas realizadas en diferentes contextos de desarrollo, investigaron cómo se aborda la seguridad usable dentro del proceso de desarrollo de software: un proceso que implica varias etapas (por ejemplo, la definición de requisitos, la escritura de código y la depuración) y diferentes partes interesadas (directivos, diseñadores, desarrolladores y clientes). Los resultados de ese estudio cualitativo mostraron que el tema de la seguridad usable había recibido poca atención dentro de la comunidad de desarrolladores. Esto se debe a que, a menudo, se considera que la usabilidad tiene menor importancia que la seguridad y a que se cree que los aspectos relacionados con la usabilidad no requieren conocimientos especializados ni experiencia, sino que basta con el sentido común. Como señaló uno de los entrevistados: «Son cosas que todo el mundo tiene que aprender por su cuenta hasta cierto punto». La usabilidad se considera totalmente independiente y menos importante que la seguridad. De hecho, algunos de los entrevistados sugirieron sacrificar una para lograr la otra. El desinterés por la usabilidad se pone de manifiesto aún más claramente en circunstancias en las que, incluso a pesar de contar con especialistas, el equipo de desarrollo optó por no consultarles porque se consideraba una pérdida de tiempo.

Por otra parte, el problema radica en la ausencia de requisitos de seguridad usable en casi todos los contextos de desarrollo. Por lo tanto, este aspecto no se aborda desde las primeras conversaciones con los clientes y las partes interesadas. Del mismo modo, sin requisitos específicos, se pasa por alto la necesidad de someter las características de seguridad a evaluaciones de usabilidad. Actualmente, no existen herramientas, documentación específica, directrices ni normas para la seguridad usable, lo cual resulta bastante desconcertante si se tiene en cuenta que uno de los principales objetivos del campo de investigación de la seguridad usable es informar a los organismos de normalización.

Contribuciones de los autores: F.D.N. llevó a cabo la búsqueda bibliográfica; F.D.N., G.T. y M.O. analizaron los resúmenes y los artículos completos, redactaron el borrador inicial y editaron el manuscrito. Todos los autores han leído y dado su visto bueno a la versión publicada del manuscrito.

Financiación: Esta investigación no recibió ninguna subvención específica de ningún organismo de financiación de los sectores público, comercial o sin ánimo de lucro.

Declaración de disponibilidad de datos: En este estudio no se crearon ni analizaron datos nuevos. El intercambio de datos no es aplicable a este artículo.

Conflictos de intereses: Los autores declaran no tener ningún conflicto de intereses.

Referencias

1. Kumar, R.; Khan, A.I.; Abushark, Y.B.; Alam, M.M.; Agrawal, A.; Khan, R.A. «Un enfoque integrado de lógica difusa, AHP y TOPSIS « » para estimar la seguridad de uso de las aplicaciones web». *IEEE Access* **2020**, *8*, 50944–50957. [\[CrossRef\]](#)
2. Steinbart, P.J.; Keith, M.J.; Babb, J. Análisis de la continuidad del comportamiento seguro: un estudio de campo longitudinal sobre la autenticación « » en dispositivos móviles. *Inf. Syst. Res.* **2016**, *27*, 219–239. [\[CrossRef\]](#)
3. Florêncio, D.; Herley, C.; Van Oorschot, P.C. Carteras de contraseñas y el usuario {de esfuerzo finito}: gestión sostenible de un gran número de cuentas. En Actas del 23.º Simposio de Seguridad de USENIX (USENIX Security 14), San Diego, California, EE. UU., del 20 al 22 de agosto de 2014; pp. 575–590.
4. Al-Ameen, M.N.; Marne, S.T.; Fatema, K.; Wright, M.; Scielzo, S. Sobre la mejora de la facilidad de memorización de las contraseñas asignadas por el sistema basadas en el reconocimiento. *Behav. Inf. Technol.* **2022**, *41*, 1115–1131. [\[CrossRef\]](#)
5. Reuter, C.; Iacono, L.L.; Benlian, A. Un cuarto de siglo de investigación sobre seguridad y privacidad usables: transparencia, personalización y el camino a seguir en materia de « ». *Behav. Inf. Technol.* **2022**, *41*, 2035–2048. [\[CrossRef\]](#)
6. Distler, V.; Fassel, M.; Habib, H.; Krombholz, K.; Lenzini, G.; Lallemand, C.; Cranor, L. F.; Koenig, V. Una revisión bibliográfica sistemática de los métodos empíricos y la representación del riesgo en la investigación sobre privacidad y seguridad orientada a la usabilidad. *ACM Trans. Comput.-Hum. Interact. (TOCHI)* **2021**, *28*, 1–50. [\[CrossRef\]](#)
7. Gaines, B.R. De facilitar la interactividad a gestionar la hiperconectividad: 50 años de estudios sobre la interacción persona-ordenador. *Int. J. Hum.-Comput. Stud.* **2019**, *131*, 4–22. [\[CrossRef\]](#)
8. Sae-Bae, N.; Wu, J.; Memon, N.; Konrad, J.; Ishwar, P. Métodos emergentes basados en la interfaz de usuario natural (NUI) para la autenticación de usuarios: una nueva taxonomía y estudio. *IEEE Trans. Biom. Behav. Identity Sci.* **2019**, *1*, 5–31. [\[CrossRef\]](#)
9. Lallie, H.S.; Shepherd, L.A.; Nurse, J.R.; Erola, A.; Epiphaniou, G.; Maple, C.; Bellekens, X. La ciberseguridad en la era de la COVID-19: cronología y análisis de los delitos y ataques cibernéticos durante la pandemia. *Comput. Secur.* **2021**, *105*, 102248. [\[CrossRef\]](#)

10. Foro Económico Mundial. Perspectivas de los riesgos de la COVID-19: un mapeo preliminar y sus implicaciones. 2020. Disponible en línea: <https://www.weforum.org/reports/covid-19-risks-outlook-a-preliminary-mapping-and-its-implications> (consultado el 1 de diciembre de 2022).
11. Lennartsson, M.; Kävrestad, J.; Nohlberg, M. «Exploring the meaning of usable security—A literature review». *Inf. Comput. Secur.* **2021**, *29*, 647–663. [CrossRef]
12. Nwokedi, U.O.; Onyimbo, B.A.; Rad, B.B. Usabilidad y seguridad en el diseño de interfaces de usuario: una revisión bibliográfica sistemática. *Int. J. Inf. Technol. Comput. Sci. (IJITCS)* **2016**, *8*, 72–80. [CrossRef]
13. Zhang, R.; Xiao, Y.; Sun, S.; Ma, H. Esquema eficiente de intercambio de claves con autenticación multifactorial para comunicaciones móviles. *IEEE Trans. Dependable Secur. Comput.* **2019**, *16*, 625–634. [CrossRef]
14. Bicakci, K.; Kiziloz, H.E. Aprovechamiento de la computación humana para pruebas de interacción humana en texto sin cifrar. *Int. J. Hum.-Comput. Stud.* **2016**, *92*, 44–54. [CrossRef]
15. Nehmadi, L.; Meyer, J. Efectos del método de autenticación y de las propiedades del sistema en las decisiones de autenticación y el rendimiento. *Revista de Ingeniería Cognitiva y Toma de Decisiones () Cogn. Eng. Decis. Mak.* **2015**, *9*, 130–148. [CrossRef]
16. Shi, C.; Xu, X.; Ji, S.; Bu, K.; Chen, J.; Beyah, R.; Wang, T. «Captchas adversarios». *IEEE Trans. Cybern.* **2021**, *52*, 6095–6108. [CrossRef]
17. Gao, S.; Mohamed, M.; Saxena, N.; Zhang, C. «Captchas de movimiento de imágenes emergentes: vulnerabilidades de los diseños existentes y contramedidas». *IEEE Trans. Dependable Secur. Comput.* **2017**, *16*, 1040–1053. [CrossRef]
18. Kiziloz, H.E.; Bicakci, K. Un análisis detallado de las pruebas de interacción humana basadas en texto puro. *IEEE Trans. Hum.-Mach. Syst.* **2016**, *47*, 994–1004. [CrossRef]
19. Xu, Y.; Reynaga, G.; Chiasson, S.; Frahm, J.M.; Monroe, F.; Van Oorschot, P.C. Análisis de seguridad y usabilidad relacionada de los captchas basados en el movimiento « »: decodificación de palabras clave en movimiento. *IEEE Trans. Dependable Secur. Comput.* **2013**, *11*, 480–493. [CrossRef]
20. Olalere, A.; Feng, J.H.; Lazar, J.; Brooks, T. Estudio de los efectos del enmascaramiento acústico en el uso de captchas de audio. *Behav. Inf. Technol.* **2014**, *33*, 919–928. [CrossRef]
21. Yan, J.; El Ahmad, A.S. Superación de captchas visuales con algoritmos de reconocimiento de patrones simples. En Actas de la XXIII Conferencia Anual sobre Aplicaciones de Seguridad Informática (ACSAC), Miami Beach, FL, EE. UU., 10-14 de diciembre de 2007; IEEE: Piscataway, NJ, EE. UU., 2007; pp. 279–291.
22. Guerar, M.; Migliardi, M.; Merlo, A.; Benmohammed, M.; Palmieri, F.; Castiglione, A. Uso del brillo de la pantalla para mejorar la seguridad en el acceso a redes sociales desde dispositivos móviles. *IEEE Trans. Dependable Secur. Comput.* **2016**, *15*, 621–632. [CrossRef]
23. Khan, M.A.; Din, I.U.; Jadoon, S.U.; Khan, M.K.; Guizani, M.; Awan, K.A. G-RAT: una novedosa técnica gráfica de autenticación aleatoria para dispositivos inteligentes de consumo. *IEEE Trans. Consum. Electron.* **2019**, *65*, 215–223. [CrossRef]
24. Chiasson, S.; Stobert, E.; Forget, A.; Biddle, R.; Van Oorschot, P.C. Puntos de clic con señales persuasivas: diseño, implementación y evaluación de un mecanismo de autenticación basado en el conocimiento. *IEEE Trans. Dependable Secur. Comput.* **2011**, *9*, 222–235. [CrossRef]
25. Biddle, R.; Mannan, M.; van Oorschot, P.C.; Whalen, T. Estudio de usuarios, análisis y seguridad usable de contraseñas basadas en objetos digitales « ». *IEEE Trans. Inf. Forensics Secur.* **2011**, *6*, 970–979. [CrossRef]
26. Juang, K.; Greenstein, J. Integración de mnemotécnicos visuales y retroalimentación de entrada con frases de contraseña para mejorar la usabilidad y la seguridad de la autenticación digital. *Hum. Factors* **2018**, *60*, 658–668. [CrossRef] [PubMed]
27. Al-Ameen, M.N.; Wright, M. Exploración del potencial de Geopass: un esquema de contraseña basado en la ubicación geográfica. *Interact. Comput.* **2017**, *29*, 605–627. [CrossRef]
28. MacRae, B.; Salehi-Abari, A.; Thorpe, J. Una exploración de los esquemas de autenticación geográfica. *IEEE Trans. Inf. Forensics Secur.* **2016**, *11*, 1997–2012. [CrossRef]
29. Zhang, Y.; Han, D.; Li, A.; Zhang, L.; Li, T.; Zhang, Y. Magauth: autenticación de dos factores segura y fácil de usar con dispositivos portátiles de e magnético en la muñeca. *IEEE Trans. Mob. Comput.* **2021**, *22*, 311–327. [CrossRef]
30. Mathis, F.; Williamson, J.H.; Vaniea, K.; Khamis, M. Autenticación rápida y segura en realidad virtual mediante la manipulación y el señalamiento coordinados de un « » 3D. *ACM Trans. Comput.-Hum. Interact. (ToCHI)* **2021**, *28*, 1–44. [CrossRef]
31. Wazir, W.; Khattak, H.A.; Almogren, A.; Khan, M.A.; Din, I.U. Técnica de autenticación basada en garabatos mediante realidad aumentada. *IEEE Access* **2020**, *8*, 4022–4034. [CrossRef]
32. Li, Y.; Cheng, Y.; Meng, W.; Li, Y.; Deng, R.H. Diseño de un sistema de introducción de contraseñas resistente a las fugas en dispositivos de realidad virtual () con gafas inteligentes que se colocan en la cabeza. *IEEE Trans. Inf. Forensics Secur.* **2020**, *16*, 307–321. [CrossRef]
33. Khamis, M.; Marky, K.; Bulling, A.; Alt, F. Autenticación multimodal centrada en el usuario: protección de dispositivos móviles de mano mediante el uso de la de la mirada y la entrada táctil. *Behav. Inf. Technol.* **2022**, *41*, 2061–2083. [CrossRef]
34. Chakraborty, N.; Li, J.Q.; Mondal, S.; Luo, C.; Wang, H.; Alazab, M.; Chen, F.; Pan, Y. Sobre el diseño de un protocolo de autenticación e o menos intrusivo para prevenir amenazas basadas en el aprendizaje automático en el Internet de las cosas. *IEEE Internet Things J.* **2020**, *8*, 3255–3267. [CrossRef]
35. Hartwig, K.; Reuter, C. Cómo orientar a los usuarios hacia mejores decisiones de seguridad en la creación de contraseñas mediante visualizaciones multidimensionales basadas en «caja blanca». *Behav. Inf. Technol.* **2022**, *41*, 1357–1380. [CrossRef]
36. Alharbi, A.; Alharbi, T. Diseño y evaluación de un marco de autenticación para dispositivos wearables. *IEEE Access* **2020**, *8*, 80369–80381. [CrossRef]
37. Perkovic, T.; Čagalj, M.; Mastelic, T.; Saxena, N.; Begušić, D. Inicialización segura de múltiples dispositivos inalámbricos con restricciones para un usuario sin ayuda. *IEEE Trans. Mob. Comput.* **2012**, *11*, 337–351. [CrossRef]
38. Leguesse, Y.; Colombo, C.; Vella, M.; Hernández-Castro, J. PoPL: Prueba de presencia y localidad, o cómo proteger las transacciones financieras en tu smartphone. *IEEE Access* **2021**, *9*, 168600–168612. [CrossRef]

39. Ali, M.; Baloch, A.; Waheed, A.; Zareei, M.; Manzoor, R.; Sajid, H.; Alanazi, F. Un esquema de contraseña sencillo y seguro basado en la reformulación. *IEEE Access* **2021**, *9*, 11655–11674. [\[CrossRef\]](#)
40. Zimmermann, V.; Gerber, N. «La contraseña ha muerto, larga vida a la contraseña: un estudio de laboratorio sobre las percepciones de los usuarios respecto a los esquemas de autenticación». *Int. J. Hum.-Comput. Stud.* **2020**, *133*, 26–44. [\[CrossRef\]](#)
41. Weir, C.S.; Douglas, G.; Richardson, T.; Jack, M. Seguridad usable: preferencias de los usuarios respecto a los métodos de autenticación en la banca electrónica y los efectos de la experiencia. *Interact. Comput.* **2010**, *22*, 153–164. [\[CrossRef\]](#)
42. Flechais, I.; Sasse, M.A. Participación de las partes interesadas, motivación, responsabilidad, comunicación: cómo diseñar una seguridad usable en la e-ciencia. *Int. J. Hum.-Comput. Stud.* **2009**, *67*, 281–296. [\[CrossRef\]](#)
43. Alsharnouby, M.; Alaca, F.; Chiasson, S. «Por qué el phishing sigue funcionando: estrategias de los usuarios para combatir los ataques de phishing». *Int. J. Hum.-Comput. Stud.* **2015**, *82*, 69–82. [\[CrossRef\]](#)
44. Roth, V.; Straub, T.; Richter, K. Ingeniería de seguridad y usabilidad con especial atención al correo electrónico. *Int. J. Hum.-Comput. Stud.* **2005**, *63*, 51–73. [\[CrossRef\]](#)
45. Gorski, P.L.; Möller, S.; Wiefing, S.; Iacono, L.L. «¡Solo busqué la solución!». Sobre la integración de información relevante para la seguridad en la documentación de una API no relacionada con la seguridad de para respaldar prácticas de programación seguras. *IEEE Trans. Softw. Eng.* **2021**, *48*, 3467–3484. [\[CrossRef\]](#)
46. Dhillon, G.; Oliveira, T.; Susarapu, S.; Caldeira, M. La disyuntiva entre la seguridad de la información y la usabilidad: desarrollo de objetivos de « » basados en el valor. *Comput. Hum. Behav.* **2016**, *61*, 656–666. [\[CrossRef\]](#)
47. Alemerien, K. Patrones de seguridad fáciles de usar para el diseño de sitios web de redes sociales. *Int. J. Technol. Hum. Interact. (IJTHI)* **2017**, *13*, 39–60. [\[CrossRef\]](#)
48. Merdenyan, B.; Petrie, H. Dos estudios sobre las percepciones del riesgo, los beneficios y la probabilidad de adoptar comportamientos de gestión de contraseñas. *Behav. Inf. Technol.* **2022**, *41*, 2514–2527. [\[CrossRef\]](#)
49. Haque, S.T.; Wright, M.; Scielzo, S. Jerarquía de las contraseñas web de los usuarios: percepciones, prácticas y vulnerabilidades. *Int. J. Hum.-Comput. Stud.* **2014**, *72*, 860–874. [\[CrossRef\]](#)
50. Hirschprung, R.S.; Tayro, S.; Reznik, E. Optimización de la adquisición de competencias tecnológicas para proteger la privacidad y la seguridad. *Behav. Inf. Technol.* **2022**, *41*, 922–933. [\[CrossRef\]](#)
51. Gopavaram, S.R.; Bhide, O.; Camp, L.J. «¿Me oyes ahora? Interacciones audiovisuales que influyen en la elección de aplicaciones». *Front. Psychol.* **2020**, *11*, 2227. [\[CrossRef\]](#)
52. Gates, C.S.; Chen, J.; Li, N.; Proctor, R.W. Comunicación eficaz de riesgos para aplicaciones de Android. *IEEE Trans. Dependable Secur. Comput.* **2013**, *11*, 252–265. [\[CrossRef\]](#)
53. Chen, J.; Gates, C.S.; Li, N.; Proctor, R.W. Influencia del encuadre de la información sobre riesgos y seguridad en las decisiones de instalación de aplicaciones para Android. *J. Cogn. Eng. Decis. Mak.* **2015**, *9*, 149–168. [\[CrossRef\]](#)
54. Wu, D.; Moody, G.D.; Zhang, J.; Lowry, P.B. Efectos del diseño de las notificaciones de seguridad en dispositivos móviles y de la usabilidad de las aplicaciones móviles en las percepciones de seguridad de los usuarios de « » y en su intención de seguir utilizándolas. *Inf. Manag.* **2020**, *57*, 103235. [\[CrossRef\]](#)
55. Alshamsi, A.; Andras, P. Percepción de los usuarios novatos sobre la usabilidad y la seguridad de Bitcoin. *Int. J. Hum.-Comput. Stud.* **2019**, *126*, 94–110. [\[CrossRef\]](#)
56. Zhang, J.; Luximon, Y. Diseño de interacción para la seguridad basado en el contexto social. *Int. J. Hum.-Comput. Stud.* **2021**, *154*, 102675. [\[CrossRef\]](#)
57. Mohamed, M.A.; Chakraborty, J.; Dehlinger, J. Equilibrio entre usabilidad y seguridad en el diseño de interfaces de usuario a través de modelos mentales. *Behav. Inf. Technol.* **2017**, *36*, 493–516. [\[CrossRef\]](#)
58. Al-Zahrani, F.A. Evaluación de la usabilidad y la seguridad del software sanitario mediante una técnica unificada de lógica difusa, ANP y TOPSIS. *IEEE Access* **2020**, *8*, 109905–109916. [\[CrossRef\]](#)
59. Kumar, R.; Baz, A.; Alhakami, H.; Alhakami, W.; Baz, M.; Agrawal, A.; Khan, R.A. Un modelo híbrido de análisis de toma de decisiones mediante la lógica difusa vacilante () para estimar la seguridad de uso del software. *IEEE Access* **2020**, *8*, 72694–72712. [\[CrossRef\]](#)
60. Di Nocera, F.; Tempestini, G. «Cómo eliminar la disyuntiva entre usabilidad y seguridad: un enfoque conductual». *J. Cybersecur. Priv.* **2022**, *2*, 245–256. [\[CrossRef\]](#)
61. Bravo-Lillo, C.; Cranor, L.; Komanduri, S.; Schechter, S.; Sleeper, M. ¿Más difícil de ignorar? Una revisión de la fatiga provocada por las ventanas emergentes y los enfoques para prevenirla. En Actas del 10.º Simposio sobre Privacidad y Seguridad Usables (SOUPS 2014), Menlo Park, California, EE. UU., del 9 al 11 de julio de 2014; pp. 105–111.
62. Bravo-Lillo, C.; Komanduri, S.; Cranor, L.F.; Reeder, R.W.; Sleeper, M.; Downs, J.; Schechter, S. «Su atención, por favor: Diseño de interfaces de usuario para decisiones de seguridad que hagan más difícil ignorar los riesgos reales». En Actas del Noveno Simposio sobre Privacidad y Seguridad Usables (), Newcastle, Reino Unido, 24–26 de julio de 2013; pp. 1–12.
63. Bhana, B.; Flowerday, S.V. Usabilidad del proceso de autenticación de inicio de sesión: frases de contraseña y contraseñas. *Inf. Comput. Secur.* **2022**, *30*, 280–305. [\[CrossRef\]](#)
64. Gutfleisch, M.; Klemmer, J.H.; Busch, N.; Acar, Y.; Sasse, M.A.; Fahl, S. ¿Cómo (no) acaba incorporándose la seguridad usable en los productos de software? Resultados de un estudio de entrevistas cualitativas. En Actas del 43.º Simposio del IEEE sobre Seguridad y Privacidad (S&P), San Francisco, CA, EE. UU., 22–26 de mayo de 2022; IEEE: Piscataway, NJ, EE. UU., 2022.

Descargo de responsabilidad/Nota del editor: Las declaraciones, opiniones y datos contenidos en todas las publicaciones son exclusivamente de los autores y colaboradores individuales, y no de MDPI ni de los editores. MDPI y los editores declinan toda responsabilidad por cualquier daño a personas o bienes que resulte de las ideas, métodos, instrucciones o productos mencionados en el contenido.